

Order Risk Hold for imported Shopify orders

System Design Document. Holding fraudulent orders in the ERP before they can be delivered.

PREPARED BY	Nikola Djurovic
PREPARED FOR	Portfolio, nikoladjurovic.cv
PURPOSE	Business analysis work sample
DOCUMENT TYPE	System Design Document
VERSION	1.0
STATUS	Final, published as a work sample
DATE	September 2026

USE OF THIS DOCUMENT

This document was prepared by Nikola Djurovic as a business analysis work sample. It is published so that his work can be assessed. It may not be used, copied, adapted, distributed or implemented for product development or for any other commercial purpose without the author's written permission. All rights reserved.

Table of Contents

1. Functional Requirements.....	4
1.1 Problem Statement.....	4
1.2 User Scenarios.....	4
1.3 Requirements.....	5
1.4 Proposed Solution.....	6
2. Functional Specification.....	6
2.1 Solution Design.....	6
2.1.1 Risk data taken from Shopify.....	6
2.1.2 Deriving <i>Risk Level</i>	7
2.1.3 Effect on status.....	7
2.1.4 Settings.....	7
2.1.5 Exception handling.....	8
2.1.6 Order import workflow.....	9
2.1.7 Order status flow.....	10
2.1.8 Risk refresh on a later import run.....	11
2.2 UI Screens.....	12
2.2.1 Sales Order, header.....	12
2.2.2 Dialog, medium risk confirmation.....	14
2.2.3 Dialog, release of a high risk hold.....	14
2.2.4 Tab <i>Order Risk</i>	15
2.2.5 Order list.....	15
2.3 API.....	15
2.4 Database Changes.....	16
3. Testing Strategy.....	17
3.1 Acceptance Criteria.....	18
3.2 Automated Testing.....	19
3.3 Manual Testing.....	20
4. Simplifications, limitations and open questions.....	20
Appendix A. Data examples.....	21

Table of Figures

Figure 1 - Order import with Order Risks.....	9
Figure 2 - Sales Order status flow.....	10
Figure 3 - Risk refresh on a later import run.....	11
Figure 4 - Sales Order screen with the new risk controls.....	12
Figure 5 - Medium risk confirmation dialog and the new Order Risk tab.....	12

Field	Value
Author	Nikola Djurovic
Status	DRAFT
Approval Deadline	to be set with the sales manager
Product Version	ERP release to be confirmed
Reference	Shopify Admin GraphQL, OrderRiskSummary, RiskAssessmentResult, OrderRiskRecommendationResult

Scope note:

The existing Sales Order screen and the existing Shopify to ERP integration are out of scope. This document specifies only the risk fields, the risk evaluation step inside the existing import, and the delivery restrictions that follow from it.

1. Functional Requirements

1.1 Problem Statement

Fraudulent orders paid with stolen cards are increasing on the Shopify store. Shopify runs a fraud analysis on each order and returns a risk assessment and a recommendation (accept; investigate; cancel), but that output stops at Shopify.

The ERP imports the order every 10 minutes with no risk data attached, so the sales manager sees a normal Sales Order and can invoice it or schedule delivery without knowing that Shopify flagged it.

This creates two problems and associated cost:

1. Goods leave the warehouse on orders that are later charged back, so the company loses the stock, the shipping cost and the card amount.
2. The sales manager has no record of who released a suspicious order and why, so chargeback disputes cannot be reconstructed.

The risk information already exists at the moment of import. The gap is that the ERP does not store it and does not act on it.

1.2 User Scenarios

Scenario 1. High risk order reaches delivery today:

An order for three cameras, EUR 2 480, is placed with a card issued in a different country from the shipping address. Shopify assesses the order as high risk and recommends cancelling it. The order imports into the ERP 10 minutes later with status *Open*. The sales manager processes the daily queue, presses *Create Shipment*, and the goods ship the same afternoon. The chargeback arrives four weeks later.

Scenario 2. Medium risk order, no signal to the user:

Shopify assesses an order as medium risk and recommends investigating it. In the ERP the order looks identical to every other order. The sales manager has no reason to call the customer, so the check that would have caught the fraud never happens.

Scenario 3. Legitimate customer wrongly flagged:

A returning customer orders while traveling, so the IP country does not match the billing country. Shopify returns medium risk. The sales manager calls the customer, confirms the order, and needs to ship it the same day. Any control the ERP adds has to allow this delivery to proceed and has to record who allowed it.

Scenario 4. Risk analysis not finished at import time:

The import job runs 10 minutes after checkout and Shopify has not completed the fraud analysis, so the risk assessment comes back as pending. The order must still import, and it must not be treated as safe.

1.3 Requirements

Priority of scope defined by MoSCoW.

Functional Requirements:

ID	Requirement	Priority
FR-01	The import stores the Shopify risk assessments, the risk facts and the Shopify recommendation on the imported Sales Order.	Must
FR-02	The ERP derives a single <i>Risk Level</i> per order from the assessments, using the highest severity returned.	Must
FR-03	An order with <i>Risk Level</i> = <i>High</i> or <i>Medium</i> is set to status <i>Risk Hold</i> at import.	Must
FR-04	A user cannot create a shipment for an order that is on hold at <i>High</i> risk.	Must
FR-05	A user can create a shipment for an order on hold at <i>Medium</i> risk after confirming a warning and entering a reason.	Must
FR-06	Releasing a <i>High</i> risk hold requires the new <i>Risk Override</i> right. The release records user, timestamp and reason.	Must
FR-07	Risk fields, assessments and facts are visible on the Sales Order screen, read only.	Must
FR-08	An order whose risk is pending, missing or not recognized is imported, marked for review and blocked from delivery until the risk resolves.	Must
FR-09	The restriction is enforced in the order service, so the API and any background job are subject to it, not only the screen.	Must
FR-10	Risk hold behavior is driven by settings, not hard coded: which levels hold, whether unknown risk blocks, and which right releases a hold.	Should
FR-11	A later risk update from Shopify re-evaluates an order that has not shipped yet.	Should
FR-12	Orders imported before go-live are not held retroactively.	Must

Non-functional requirements:

ID	Requirement
NFR-01	The risk evaluation adds no more than 10 percent to the runtime of the existing import job at 1 000 orders per run, so the 10 minute schedule is not missed.
NFR-02	No exception in risk mapping or persistence terminates the import run or blocks the import of the order itself.
NFR-03	Every hold release is written to the audit log with user, timestamp, previous and new status, and reason. Records are retained for the chargeback dispute window.
NFR-04	Risk state is communicated by text and label, not by color alone.

Assumptions:

1. The risk information is fetched together with the order in the existing import, as stated in the task. No separate call, no webhook subscription covered by this document.
2. Shopify remains the only risk provider. Assessments from third party fraud apps are out of scope.
3. The ERP already has a permission model that can carry a new right, and a Sales Order audit log.
4. Order cancellation already exists in the ERP and is not changed here.
5. Currency, totals, customer and line-item behavior is unchanged.

1.4 Proposed Solution

The import writes the Shopify risk data onto the Sales Order and evaluates it against the hold settings before the order becomes available to the sales manager.

Orders assessed as *High* or *Medium* are imported with status *Risk Hold*. Orders whose risk is pending or unreadable are imported with status *Risk Review*. Both statuses block delivery. Everything else imports as *Open* and behaves exactly as it does today.

The block is released in one of two ways. At *Medium* risk any user with delivery rights can confirm a warning dialog and record a reason, which matches the Shopify recommendation to investigate rather than to cancel. At *High* risk only a user holding the *Risk Override* right can release the hold, which matches the recommendation to cancel. In both cases the user, the timestamp and the reason are stored on the order and in the audit log.

The check lives in the order service, not on the button. The screen reflects the state, the API returns the same refusal, and no import or background job can move goods on a held order.

2. Functional Specification

2.1 Solution Design

2.1.1 Risk data taken from Shopify

The import reads order.risk and stores:

Source	Stored as
OrderRiskSummary.recommendation	<i>Risk Recommendation</i> : ACCEPT, INVESTIGATE, CANCEL, NONE
OrderRiskSummary.assessments[].riskLevel	one row per assessment: HIGH, MEDIUM, LOW, NONE, PENDING
OrderRiskSummary.assessments[].provider	provider name, empty when the assessment comes from Shopify itself
OrderRiskSummary.assessments[].facts[]	sentiment and description, one row per fact

2.1.2 Deriving Risk Level

Shopify returns a list of assessments and one recommendation. The ERP needs one value to act on, so the mapping takes the most severe assessment. Order of evaluation:

1. any assessment HIGH gives *Risk Level = High*
2. otherwise any MEDIUM gives *Medium*
3. otherwise any PENDING gives *Pending*
4. otherwise any LOW gives *Low*
5. otherwise, all NONE or an empty list, gives *None*
6. no risk block at all, or a value outside the list above, gives *Not assessed*

Risk Recommendation is stored as returned and displayed, but it does not drive the block. The business rule from the sales manager is written in risk levels, and the recommendation is a derived suggestion that can change independently of them.

2.1.3 Effect on status

Risk Level	Status at import	Create Shipment	Create Invoice
High	Risk Hold	blocked, release requires the <i>Risk Override</i> right	allowed, see open question Q1
Medium	Risk Hold	allowed after the confirmation dialog and a reason	allowed
Pending	Risk Review	blocked until the next import run resolves the risk	allowed
Not assessed	Risk Review	blocked while the setting <i>Block delivery when risk is unknown</i> is on	allowed
Low, None	Open	allowed, no dialog	allowed

An order in *Risk Review* leaves that status in one of three ways: a later import run resolves the risk, and the order moves to *Risk Hold* or to *Open*, a user with the *Risk Override* right releases it, or the order is cancelled.

Risk Level is a separate field from *Status*. Releasing a hold moves *Status* to *Open* and leaves *Risk Level* unchanged, so the order still shows what Shopify found and the release stays visible.

2.1.4 Settings

New setup group *Order Risk Settings*, one record per company will be implemented. The setting specification is as follows:

Setting	Type	Default
Hold levels	multi select over <i>High</i> , <i>Medium</i> , <i>Low</i>	<i>High</i> , <i>Medium</i>
Block delivery when risk is unknown	yes or no	yes

Setting	Type	Default
<i>Release right for high risk</i>	permission	<i>Risk Override</i>
<i>Risk hold active from</i>	date, set at go-live	go-live date

Thresholds move with fraud patterns and with the season. Settings keep that a configuration change rather than a code change, and *Risk hold active from* keeps the open order book from freezing on release day.

2.1.5 Exception handling

Case	Behavior
order.risk missing or null	<i>Risk Level = Not assessed</i> , status <i>Risk Review</i> , warning in the integration log, order imported
Risk level or recommendation value not in the known list	value stored raw in the log, <i>Risk Level = Not assessed</i> , status <i>Risk Review</i> , error in the integration log, notification to the integration administrator, order imported
Assessment list empty	<i>Risk Level = None</i> , status <i>Open</i> , information entry in the log
Risk write fails, for example a database error on the fact rows	the order import is committed, the risk block is rolled back, <i>Risk Level = Not assessed</i> , error logged, retried on the next run
Same order imported again	risk rows for the order are replaced, header risk fields recalculated, acceptance fields preserved
Risk upgraded after release, order not yet shipped	order returns to <i>Risk Hold</i> at the new level, acceptance fields cleared, entry in the audit log
Risk decreased on an order that is on hold	<i>Risk Level</i> is updated, the hold stays. A lower level never releases a hold, because a release must carry a user and a reason. See Q6
Risk upgraded after the shipment exists	status unchanged, warning entry in the audit log and a notification to the sales manager, since the ERP cannot recall goods
Order already cancelled or closed	risk fields updated, status untouched
User without the <i>Risk Override</i> right calls the release endpoint	refused with 403, entry in the security log
Two users release the same hold at the same time	first write wins, the second gets the standard concurrency message <i>This order was changed by another user. Reload the order.</i>

No case above ends the import run. The order import and the risk evaluation are committed separately for that reason.

2.1.6 Order import workflow

Figure 1. Order import with Order Risks

First import of an order. Later runs are covered in figure 3.

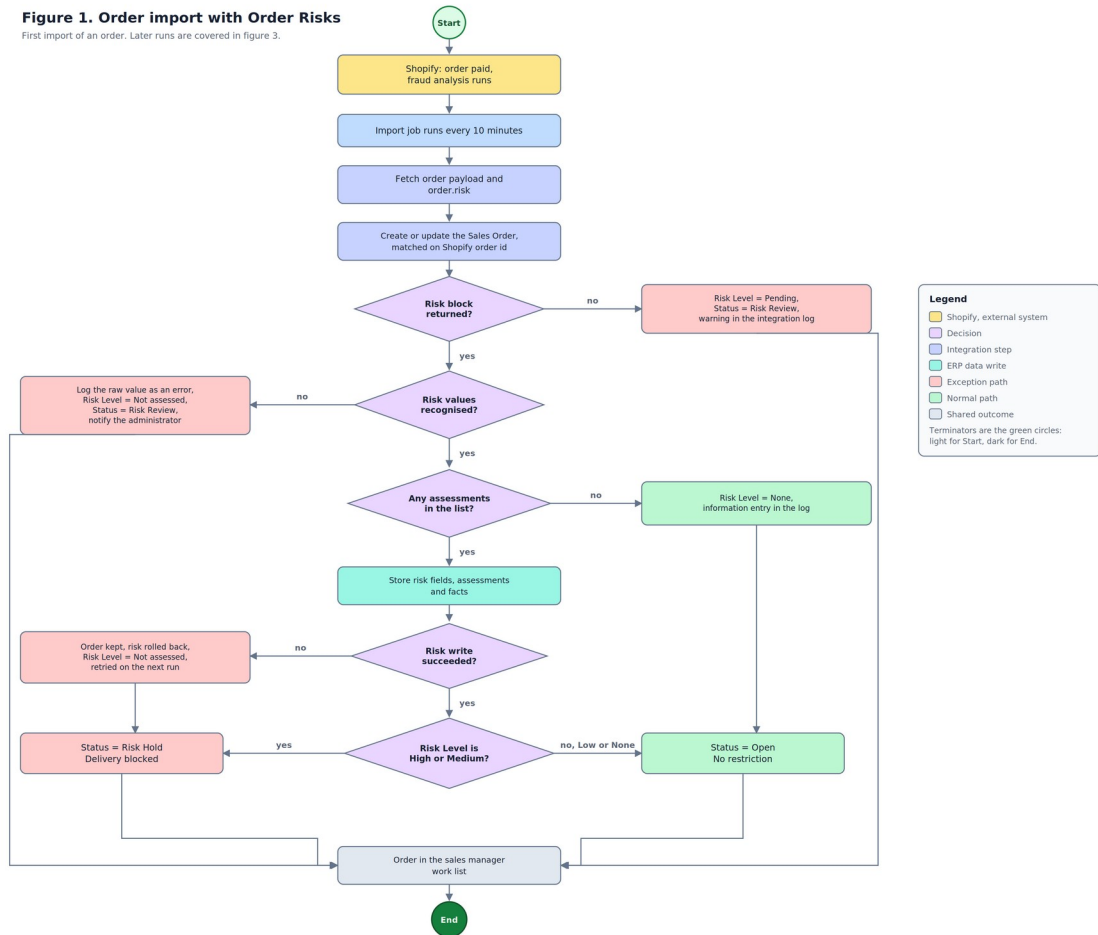


Figure 1 - Order import with Order Risks

2.1.7 Order status flow

Figure 2. Sales Order status flow

The four statuses in 2.1.3 and the events that move an order between them.

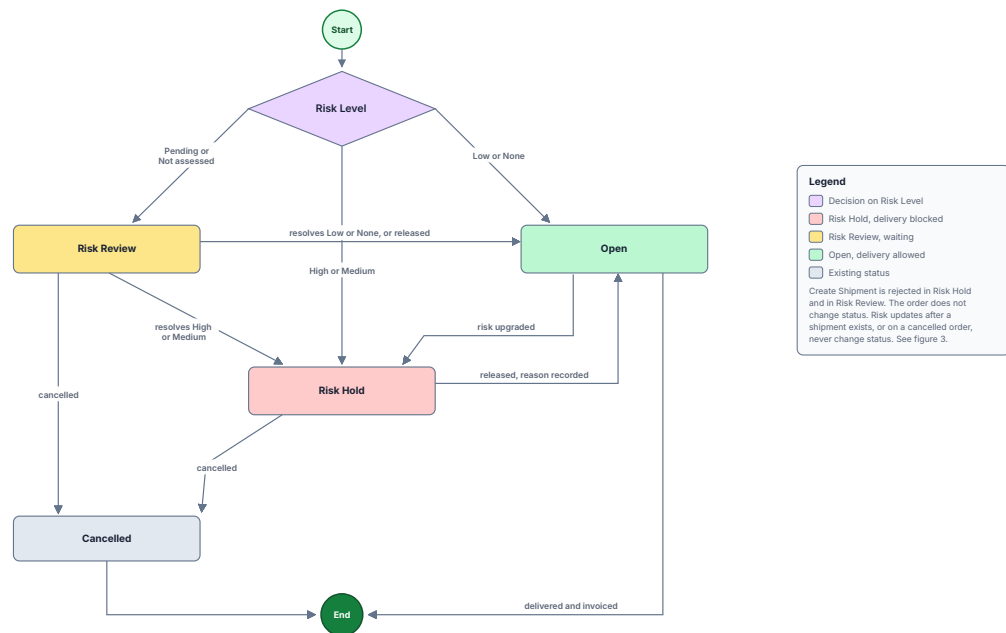


Figure 2 - Sales Order status flow

2.1.8 Risk refresh on a later import run

The import job runs every 10 minutes and returns the same order many times. This is FR-11 and the lifecycle rows of 2.1.5 in full.

Figure 3. Risk refresh on a later import run

What happens when the 10 minute job returns an order the ERP already holds.

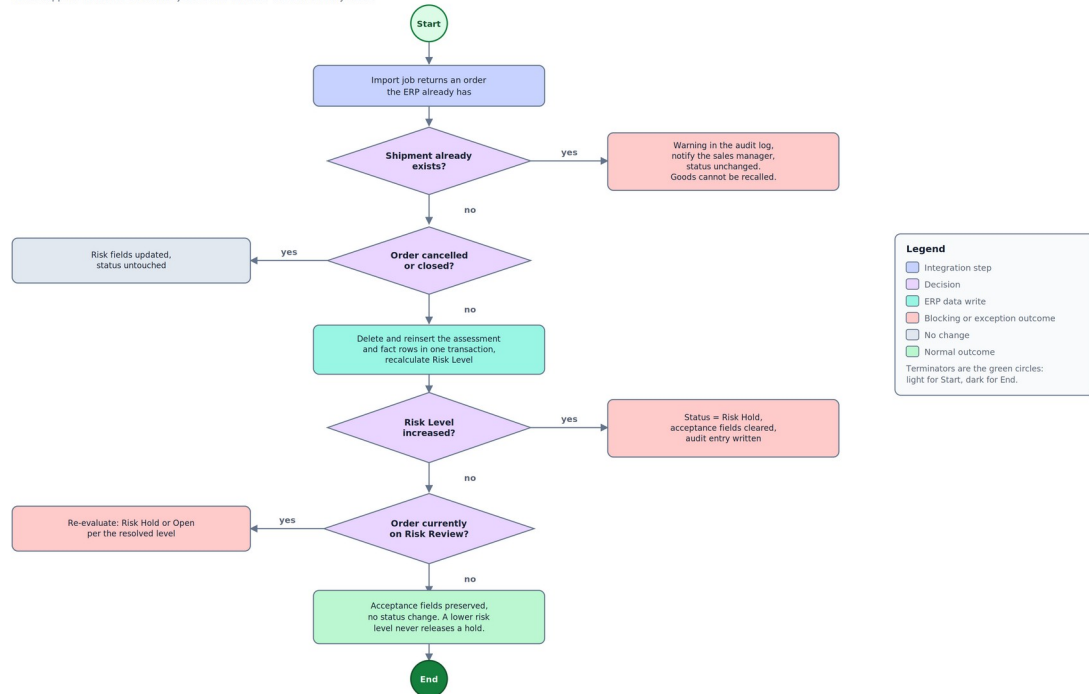


Figure 3 - Risk refresh on a later import run

2.2 UI Screens

All italic text below is UI copy for technical writer review.

Figure 4. Sales Order screen with the new risk controls

The existing screen from the task, with the new controls inserted. New controls are outlined in blue. Italic text is UI copy for technical writer review.

Behavior of the new controls

- 1 Risk banner. Visible only when Risk Level is High, Medium, Pending or Not assessed. Read only. The text changes per level.
- 2 Create Shipment. Disabled at High, Pending and Not assessed. At Medium it opens the confirmation dialog first. Unchanged at Low and None.
- 3 Status. Existing field, read only, two new values: Risk Hold and Risk Review.
- 4 Order Risk group. Always visible, all fields read only, written by the import.
- 5 Risk details. Always visible and enabled. Opens the Order Risk tab.
- 6 Release Risk Hold. Visible on Risk Hold and Risk Review. Enabled only for users holding the Risk Override right.
- 7 Order Risk tab. New tab, read only, lists the assessments and their facts.

Figure 4 - Sales Order screen with the new risk controls

Medium risk confirmation dialog

Confirm delivery of a medium risk order

Shopify assessed this order as Medium risk and recommends investigating it. Confirm only after you have checked the customer.

Reason (mandatory, 10 to 250 characters)

Customer confirmed by phone, address matches previous orders.

Cancel Confirm

Confirm stays disabled until the reason has at least 10 characters. Cancel closes the dialog and changes nothing. Confirm writes the reason, the user and the timestamp, sets Status to Open and continues to the shipment.

Data shown is illustrative. Risk Level values come from Shopify RiskAssessmentResult (HIGH, MEDIUM, LOW, NONE, PENDING). Recommendation values come from OrderRiskRecommendationResult (ACCEPT, INVESTIGATE, CANCEL, NONE).

Order Risk tab, read only

Provider	Risk level	Sentiment	Fact description
Shopify	High	Negative	Card issuer country differs from shipping
Shopify	High	Negative	Billing address does not match card address
Shopify	Low	Positive	Customer has 2 previous orders

Empty state, shown when no assessment was returned:
Shopify has not returned a risk assessment for this order yet.

The tab shows one row per fact per assessment. Sorting and filtering follow the standard grid behavior. No editing, no delete, no manual risk entry in this release.

Figure 5 - Medium risk confirmation dialog and the new Order Risk tab

2.2.1 Sales Order, header

The tables below cover every control that is new or changed on the order header. Italic text is UI copy for technical writer review.

New controls

Control	Visible when	Enabled when	Values accepted	Action
Risk banner	<i>Risk Level is High, Medium, Pending or Not assessed.</i> Hidden otherwise	Always, read only	None, display only	Shows the message for the current risk level. Message copy in the table below

Control	Visible when	Enabled when	Values accepted	Action
<i>Order Risk field group</i>	Always	Always, read only	None, populated by the import	Shows the risk data stored on the order. Fields listed below
<i>Button Risk details</i>	Always	Always	Not applicable	Opens the <i>Order Risk</i> tab
<i>Button Release Risk Hold</i>	<i>Status is Risk Hold or Risk Review</i>	Only for users holding the <i>Risk Override</i> right. Otherwise disabled with the tooltip <i>You do not have the right to release a risk hold.</i>	Not applicable	Opens the release dialog described in 2.2.3

Changed existing controls

Control	Change	Enabled when	Tooltip when disabled
Field <i>Status</i>	Two new values, <i>Risk Hold</i> and <i>Risk Review</i> . Remains read only	Unchanged	Not applicable
Button <i>Create Shipment</i>	Now subject to the risk rule	Disabled at <i>High</i> , <i>Pending</i> and <i>Not assessed</i> . At <i>Medium</i> it is enabled and opens the confirmation dialog in 2.2.2 first. Unchanged at <i>Low</i> and <i>None</i>	<i>Delivery is blocked because of the order risk. Release the risk hold first.</i>
Button <i>Create Invoice</i>	None in this release, see Q1	Unchanged	Not applicable

Fields in the Order Risk group

All fields are read only and are written by the import.

Field	Values	Empty when
<i>Risk Level</i>	<i>High, Medium, Low, None, Pending, Not assessed</i>	Never, defaults to <i>Not assessed</i>
<i>Risk</i>	<i>Accept, Investigate, Cancel, None</i>	No risk block was received

Field	Values	Empty when
<i>Recommendation</i>		
<i>Risk Checked On</i>	Date and time, shown in the user time zone, stored in UTC	No risk block was received
<i>Risk Accepted By</i>	User name	The hold has never been released
<i>Risk Accepted On</i>	Date and time	The hold has never been released

Risk banner message copy

Risk Level	Message
<i>High</i>	<i>This order was assessed as High risk in Shopify. Delivery is blocked. Shopify recommendation: Cancel. Open Risk details to review the assessment.</i>
<i>Medium</i>	<i>This order was assessed as Medium risk in Shopify. Check the customer before you deliver. Shopify recommendation: Investigate.</i>
<i>Pending</i>	<i>Shopify has not finished the fraud analysis for this order. Delivery is blocked until the analysis completes.</i>
<i>Not assessed</i>	<i>No risk assessment was received for this order. Delivery is blocked. Contact the integration administrator.</i>
<i>After a release</i>	<i>Risk accepted by {user} on {date time}. Reason: {reason}.</i>

2.2.2 Dialog, medium risk confirmation

Opens from *Create Shipment* when *Risk Level* = *Medium* and the hold has not been released yet.

- **Title:** *Confirm delivery of a medium risk order*
- **Body:** *Shopify assessed this order as Medium risk and recommends investigating it. Confirm only after you have checked the customer.*
- **Field Reason**, free text, mandatory, 10 to 250 characters, single line breaks allowed. Leading and trailing spaces are trimmed before the length check.
- **Button Confirm**, disabled until *Reason* holds at least 10 characters. On confirm the system writes *Risk Accepted By*, *Risk Accepted On* and the reason, sets *Status* = *Open*, and continues to the shipment.
- **Button Cancel**, always enabled. Closes the dialog and changes nothing.
- **Validation message** under the field: *Enter a reason of at least 10 characters.*

2.2.3 Dialog, release of a high risk hold

Opens from *Release Risk Hold*. Same layout as 2.2.2 with different copy.

- **Title:** *Release the risk hold*

- **Body:** *Shopify assessed this order as High risk and recommends cancelling it. Releasing the hold allows delivery. This action is recorded.*
- **Field Reason**, mandatory, 10 to 250 characters.
- **Buttons Release** and **Cancel**.
- Available only to users with the *Risk Override* right. A user without the right never reaches this dialog.

2.2.4 Tab Order Risk

New tab next to *DETAILS*, read only, no add, no edit, no delete.

Grid columns: *Provider, Risk level, Sentiment, Fact description*, one row per fact. Default sort by *Risk level* descending. Standard grid filtering.

Empty state: *Shopify has not returned a risk assessment for this order yet.*

2.2.5 Order list

Risk Level is added as an optional column and as a filter. A sales manager needs to find every held order without opening them one by one.

2.3 API

Two API surfaces are affected.

Inbound, Shopify to ERP. The existing import query is extended with the risk block. No new endpoint, no new schedule.

```
query($id: ID!) {
  order(id: $id) {
    id
    name
    risk {
      recommendation
      assessments {
        riskLevel
        provider { title }
        facts { sentiment description }
      }
    }
  }
}
```

The integration pins an API version. OrderRisk was deprecated in favour of the assessment model, so a contract test guards the payload shape at each version bump.

Outbound, ERP API:

Endpoint	Change
GET /salesorders/{id}	new read only fields: riskLevel, riskRecommendation, riskCheckedOn, riskAcceptedBy, riskAcceptedOn,

Endpoint	Change
	riskAcceptanceReason
GET /salesorders/{id}/risk	new, returns the assessments and facts
POST /salesorders/{id}/risk-acceptance	new, body { "reason": "..." }. 200 on release, 400 when the reason fails validation, 403 without the <i>Risk Override</i> right at <i>High</i> risk, 409 when the order is not held
POST /salesorders/{id}/shipments	existing. Now returns 409 with error code ORDER_RISK_BLOCKED and message <i>Delivery is blocked because of the order risk</i> . when the order is held
GET /salesorders?riskLevel=HIGH	new filter parameter

409 on the shipment endpoint is a breaking change for any client that assumes a shipment always succeeds on an open order. It should be listed in the release notes and covered by a contract test.

2.4 Database Changes

Existing table **SalesOrderHeader**, new columns.

Column	Type	Null	Default
RiskLevel	varchar(12)	no	NOT_ASSESSED
RiskRecommendation	varchar(12)	yes	null
RiskCheckedOn	datetime, UTC	yes	null
RiskAcceptedBy	user id, FK	yes	null
RiskAcceptedOn	datetime, UTC	yes	null
RiskAcceptanceReason	varchar(250)	yes	null

Index on (RiskLevel, Status) for the order list filter.

Existing status list. Two values added: RISK_HOLD, RISK_REVIEW.

New table SalesOrderRiskAssessment.

Column	Type	Null
Id	bigint, PK	no
SalesOrderId	FK to SalesOrderHeader, cascade delete	no
Provider	varchar(100), empty for Shopify	yes
RiskLevel	varchar(12)	no
ImportedOn	datetime, UTC	no

New table SalesOrderRiskFact.

Column	Type	Null
Id	bigint, PK	no
AssessmentId	FK to SalesOrderRiskAssessment, cascade delete	no
Sentiment	varchar(12)	yes
Description	varchar(500)	yes

New table OrderRiskSettings, one row per company, holding the four settings from 2.1.4.

Refresh rule. On re-import, assessment and fact rows for the order are deleted and reinserted in one transaction. Shopify returns the full list every time, and merging by identity would need a stable assessment key that the payload does not guarantee.

Migration. Existing orders receive RiskLevel = NOT_ASSESSED and no status change. The *Risk hold active from* setting keeps them out of the hold logic, so the release does not freeze open orders. Raw enum values are stored as text rather than as a numeric lookup, so an unknown value from a future Shopify version can be captured and logged instead of failing the write.

3. Testing Strategy

The feature blocks money moving in one direction and lets a user override that block in the other. Testing weight goes on the rule engine, the permission check and the audit trail rather than on the screen layout.

Quality attributes covered: functional correctness of the mapping, data integrity across import and re-import, authorisation, auditability, fault tolerance of the import job, performance of the batch, and no regression on the existing order to cash path.

3.1 Acceptance Criteria

AC-01, positive. High risk order is held at import

Given an order arrives from Shopify with one assessment at HIGH and recommendation CANCEL

When the import job processes the order

Then the Sales Order is created with *Status = Risk Hold* and *Risk Level = High* And the risk banner shows the high risk text And *Create Shipment* is disabled And the *Order Risk* tab lists the assessment and its facts

AC-02, positive. Medium risk order is delivered with a recorded reason

Given an order has *Risk Level = Medium* and *Status = Risk Hold* And the user has delivery rights

When the user presses *Create Shipment*, enters *Customer confirmed by phone* and presses *Confirm*

Then *Status* becomes *Open* And *Risk Accepted By*, *Risk Accepted On* and the reason are stored and shown And the shipment is created And the audit log holds one entry with the previous status, the new status, the user and the reason

AC-03, positive. Low risk order is untouched

Given an order arrives with all assessments at LOW and recommendation ACCEPT

When the import job processes the order

Then *Status = Open*, *Risk Level = Low*, no banner is shown and *Create Shipment* behaves as it does today

AC-04, positive. High risk hold released by an authorized user

Given an order has *Risk Level = High* and *Status = Risk Hold* And the user holds the *Risk Override* right

When the user presses *Release Risk Hold*, enters a reason of at least 10 characters and confirms Then *Status* becomes *Open*, *Risk Level* stays *High*, the acceptance fields are filled and *Create Shipment* becomes enabled

AC-05, negative. Cancelled confirmation changes nothing

Given an order has *Risk Level = Medium* and *Status = Risk Hold*

When the user presses *Create Shipment* and then *Cancel* in the dialog

Then no shipment exists, *Status* stays *Risk Hold*, the acceptance fields stay empty and no audit entry is written

AC-06, negative. Release refused without the right

Given an order has *Risk Level = High* and *Status = Risk Hold* And the user does not hold the *Risk Override* right

Then *Release Risk Hold* is disabled with the tooltip *You do not have the right to release a risk hold*. And a direct call to `POST /salesorders/{id}/risk-acceptance` returns 403 and writes a security log entry And a direct call to `POST /salesorders/{id}/shipments` returns 409 ORDER_RISK_BLOCKED

AC-07, negative. Unknown risk value does not break the import

Given a batch of 50 orders where one carries a risk level outside the known list

When the import job runs

Then all 50 orders are imported And the affected order has *Risk Level = Not assessed* and *Status = Risk*

Review And one error entry with the raw value is written to the integration log And the job finishes with the same result on a rerun

AC-08, negative. Reason below the minimum length is refused

Given the medium risk confirmation dialog is open

When the user types *ok* in *Reason*

Then *Confirm* stays disabled and the message *Enter a reason of at least 10 characters.* is shown

AC-09, positive. Pending risk resolves on a later run

Given an order was imported with *Risk Level = Pending* and *Status = Risk Review*

When a later import run returns an assessment at MEDIUM

Then *Risk Level* becomes *Medium* and *Status* becomes *Risk Hold* And *Risk Checked On* is updated

3.2 Automated Testing

Layer	Tests	Attribute covered
Unit	Mapping table driven across all five risk levels, four recommendations, empty list, null block, unknown string, and mixed assessments where high and pending arrive together	functional correctness
Unit	Reason validation at 9, 10, 250 and 251 characters, and with leading spaces	input validation
Integration	Import of a fixture batch containing one order per risk level, asserting status, fields, assessment rows and fact rows	data integrity
Integration	Re-import of the same batch, asserting no duplicate rows and preserved acceptance fields	idempotency
API contract	Shopify payload shape checked against the pinned API version, failing the build when the risk block changes	compatibility
API	200, 400, 403 and 409 paths on the acceptance and shipment endpoints	authorisation, contract
Smoke, per release	Import one high risk and one low risk order, open both, confirm the button state	release readiness
Performance	1 000 orders in one run, each with three assessments and five facts, asserted against NFR-01	performance
Regression	Existing order to cash suite on orders with no risk data	no regression

The mapping function and the permission check are the two places where a defect ships goods or blocks the business, so both are covered by unit tests before any UI test is written.

3.3 Manual Testing

Test	Attribute covered
Permission matrix walked by role: sales manager, sales manager with <i>Risk Override</i> , warehouse user, read only user	authorization
Visual check of banner text, tooltips, disabled states and the empty state on the <i>Order Risk</i> tab	usability, copy
Technical writer review of every italic label and message in this document	copy quality
Check that risk state is readable without color, in greyscale and at 200 percent zoom	accessibility, NFR-04
UAT with the sales manager on a fixture set of 10 orders covering every level, including one release and one cancelled dialog	business acceptance
Exploratory session on concurrency: two users open the same held order and release it	reliability
Audit trail review after UAT: every release traceable to a user, a timestamp and a reason	auditability

UAT sign off by the sales manager is the release gate, because the rule they asked for is a business rule and only they can confirm the hold levels are the ones they want.

4. Simplifications, limitations and open questions

Simplifications:

1. One derived *Risk Level* per order rather than per line or per payment. Shopify assesses the order, not the line.
2. Risk is refreshed only by the existing 10-minute job. No webhook, no manual refresh button.
3. No automatic cancellation of high-risk orders. The ERP holds, a person decides.
4. Risk facts are stored as text for display and audit. They are not parsed into rules.

Limitations:

1. An order can be imported before Shopify finishes its analysis, so a first pass may show *Pending*. The order is blocked, not released, until the analysis lands.
2. Risk arriving after a shipment exists cannot recall the goods. The ERP logs and notifies only.
3. Orders created before go-live carry no risk data and are never held.
4. Manual ERP orders and orders from other channels are outside this feature.
5. Assessments from third party fraud apps are stored and mapped by the same rules but cannot be tested until such an app is installed.

Bottlenecks:

1. Every order held needs a human decision. At current fraud volumes this is a few orders a day. If Shopify tightens its model and the medium share grows, the sales manager becomes the queue. *Risk Level* on the order list and the settings in 2.1.4 are there to manage that.
2. The PENDING path depends on Shopify completing the analysis. If it does not resolve, the order sits blocked with no timeout. A follow up release should add an age alert on *Risk Review*.

Open questions:

ID	Question	Why it matters
Q1	Should <i>Create Invoice</i> also be blocked at high risk?	The task names delivery only. Invoicing a fraudulent order still books a receivable, and in some configurations an invoice can trigger a shipment.
Q2	When the risk is unknown or pending, should delivery be blocked, as specified here, or allowed?	Blocking is the safe choice and can slow shipping when Shopify is late. The default is set to block and is configurable.
Q3	Who holds the <i>Risk Override</i> right, and is one release enough or is a second approval needed above a value threshold?	Determines the permission setup and whether an approval flow is needed.
Q4	Should a medium risk hold expire automatically after a few days?	Avoids a queue of forgotten held orders.
Q5	Is the hold on medium risk correct, or should medium only warn at the point of delivery without a hold?	The task asks to hold both high and medium and to allow medium delivery with user concern. This document resolves it as hold plus release. Confirmation needed.
Q6	When Shopify lowers the risk on an order already held, should the hold clear automatically?	This document says no, because an automatic release produces a delivery with no user, no reason and no audit entry. The alternative saves manual work on false positives.

Appendix A. Data examples

Risk levels, from *RiskAssessmentResult*: HIGH, MEDIUM, LOW, NONE, PENDING.

Recommendations, from *OrderRiskRecommendationResult*: ACCEPT, CANCEL, INVESTIGATE, NONE.

Order statuses: *Open*, *Risk Hold*, *Risk Review*, *Cancelled*, plus the existing values.

Example 1, high risk.

Field	Value
Order	SO-100238

Field	Value
Assessments	Shopify HIGH, facts: negative, <i>card issuer country differs from the shipping country</i> ; negative, <i>billing address does not match the card address</i>
Recommendation	CANCEL
Risk Level	High
Status	Risk Hold
Create Shipment	disabled

Example 2, medium risk released.

Field	Value
Order	SO-100241
Assessments	Shopify MEDIUM, fact: negative, <i>IP country differs from the billing country</i>
Recommendation	INVESTIGATE
Risk Level	Medium
Status	Open after release
Risk Accepted By	J. Horak
Risk Accepted On	07/09/2026 11:32
Reason	<i>Customer confirmed by phone, address matches previous orders</i>

Example 3, pending.

Field	Value
Order	SO-100244
Assessments	Shopify PENDING, no facts
Recommendation	NONE
Risk Level	Pending
Status	Risk Review
Create Shipment	disabled

Example 4, unknown value.

Field	Value
Order	SO-100249
Payload	riskLevel: "SEVERE"

Field	Value
<i>Risk Level</i>	<i>Not assessed</i>
<i>Status</i>	<i>Risk Review</i>
Log	error, raw value SEVERE, order id, run id